

IIS Web Server Security Assessment Network Reconnaissance & Access Control

Authorized UMGC MARS Laboratory Exercise

Niknaz Sadehvandi
CST 640 — Digital Forensics Technology and Practices
Original Project: January 30, 2025

Project 1 - Introduction

In Project 1, we'll use penetration testing to check the security of a web server. To improve the server's security against cyberattacks, vulnerabilities, such as exposed sensitive data or misconfigurations, must be detected and recorded.

Intruders commit network incursions when they gain unauthorized access to a system by exploiting security flaws. These can happen due to poor access control, outdated software, or unsecured connections. Intrusions can cause data leaks, system problems, and resource misuse.

I created and examined a test directory on the IIS web server, then used Dirb to check whether it was discoverable. This exercise highlighted potential web configuration and access-control risks; it did not confirm malicious access or compromised passwords.

MARS Linux System

Based on Kali Linux, a specialized version for security testing and digital analysis.

Comes with built-in tools for analyzing networks, checking security weaknesses, and security testing tasks or authorized security assessments.

Root privileges allowed administrative operations within the authorized lab environment.

10.11.3.52 was the Linux system's assigned IP address within the authorized lab environment.

Preinstalled dirb, Nmap, and Nikto tools for reconnaissance and vulnerability evaluations.

Reachable with TurboVNC from a Windows machine.

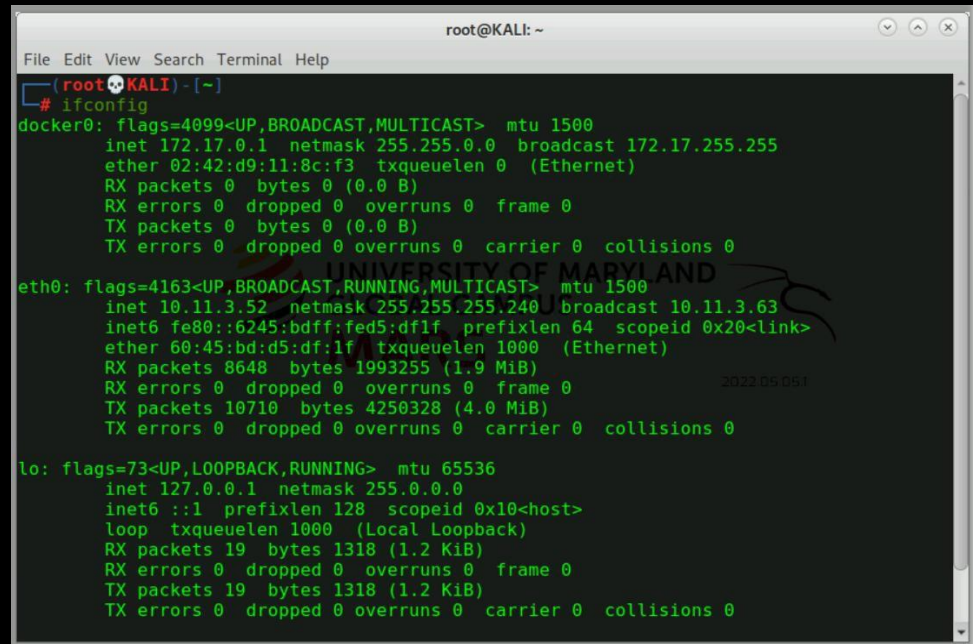
Linux Desktop

IP Address:

10.11.3.52

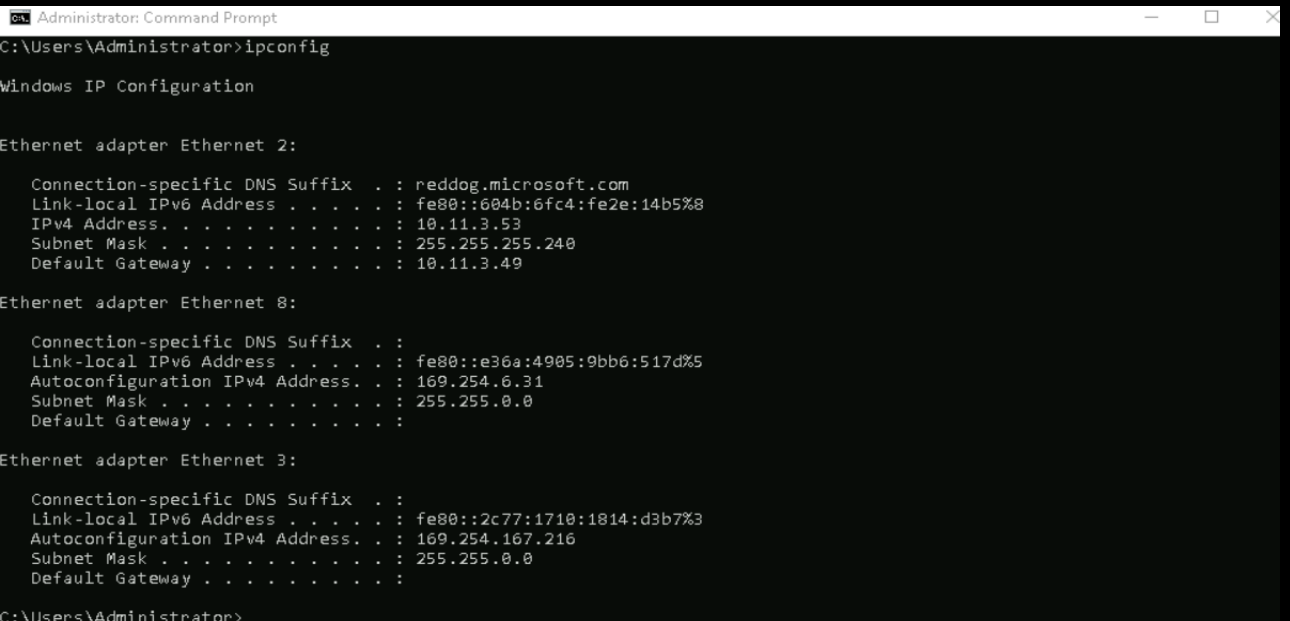
Connection Info:

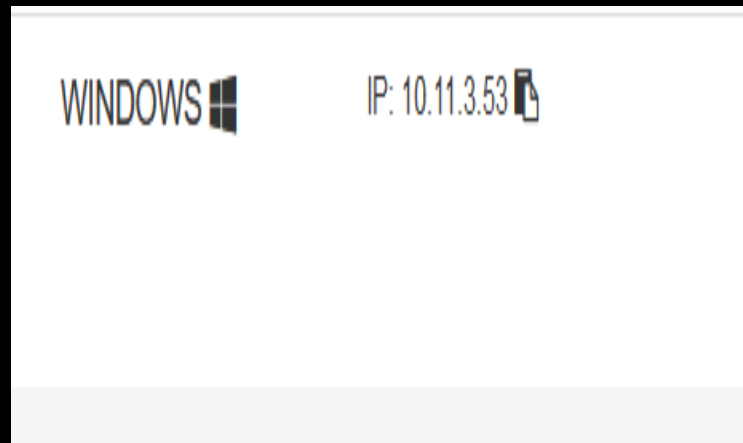
Use the TurboVNC shortcut on the desktop of your Windows Desktop to connect to your Linux Desktop.



MARS Windows System

- In the UMGC MARS laboratory, I used the Windows system for authorized security testing, including reviewing security settings, administering accounts, and configuring IIS for the web-server exercise.
- The Windows system's configured laboratory IP address was 10.11.3.53, as shown in the ipconfig output.
- The Linux machine served as the security-testing workstation, while the Windows machine hosted the IIS web-server exercise.
- The ipconfig output documented the Windows machine's lab network configuration; it did not independently confirm successful communication with the Linux machine.





IIS Setup

I used Microsoft IIS as the Windows web server in the authorized UMGC MARS laboratory.

IIS hosted the test HTML webpage created for the laboratory exercise.

I verified that the webpage loaded locally by opening http://127.0.0.1/ in the Windows system's browser.

IIS directory settings and access permissions determine which files users can access. Incorrect settings can expose content intended to remain restricted.

local IIS webpage test.

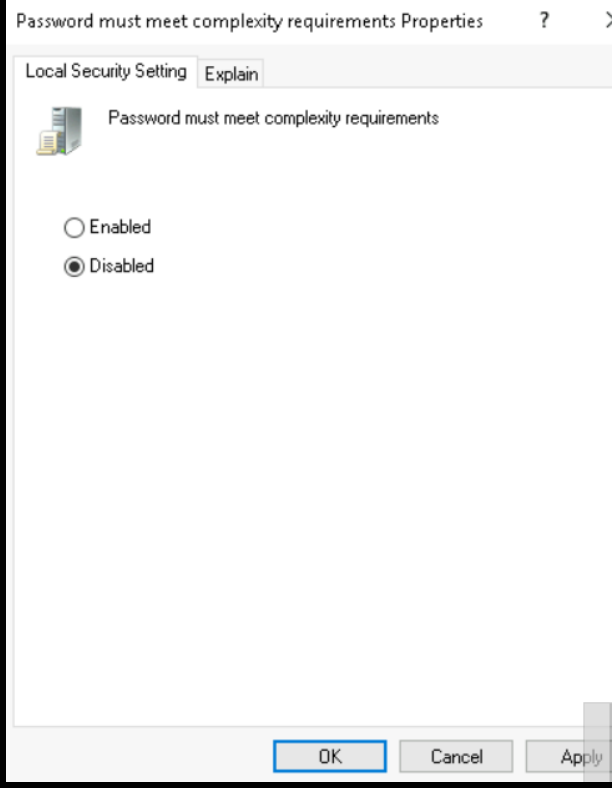


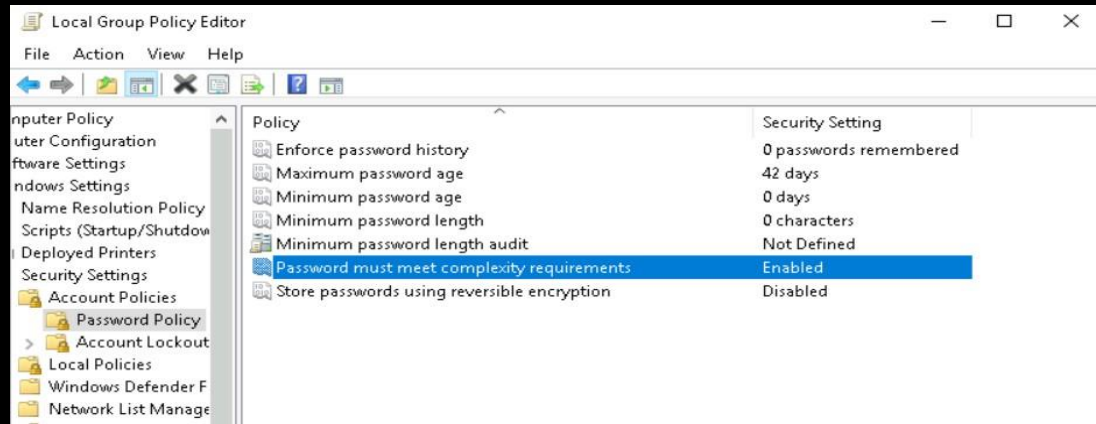
Security Policy Changes

I reviewed the Windows password-complexity setting. One screenshot shows Disabled and the other shows Enabled; the images do not establish which state was applied last.

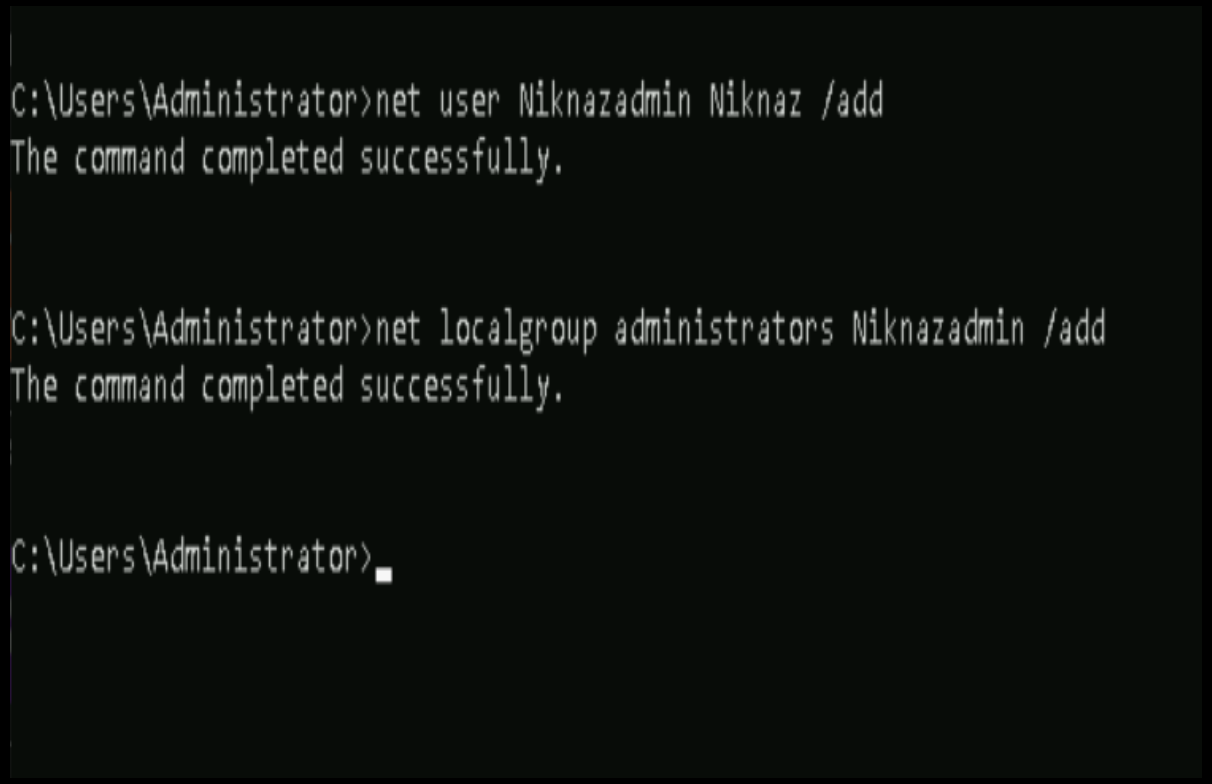
Password-policy settings must be reviewed together and their effective configuration verified. The lower screenshot shows complexity Enabled but a minimum password length of 0 characters, so it does not demonstrate a strong overall policy.

Stronger password controls can reduce risks associated with weak passwords. Enabling complexity alone, however, does not establish that the system is secure.





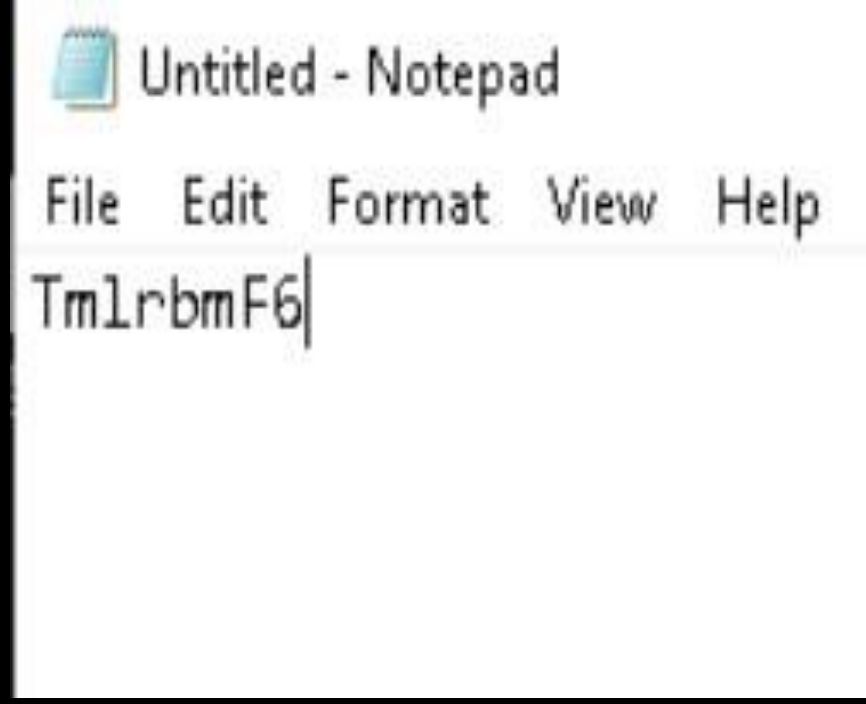
Adding an Administrative Account

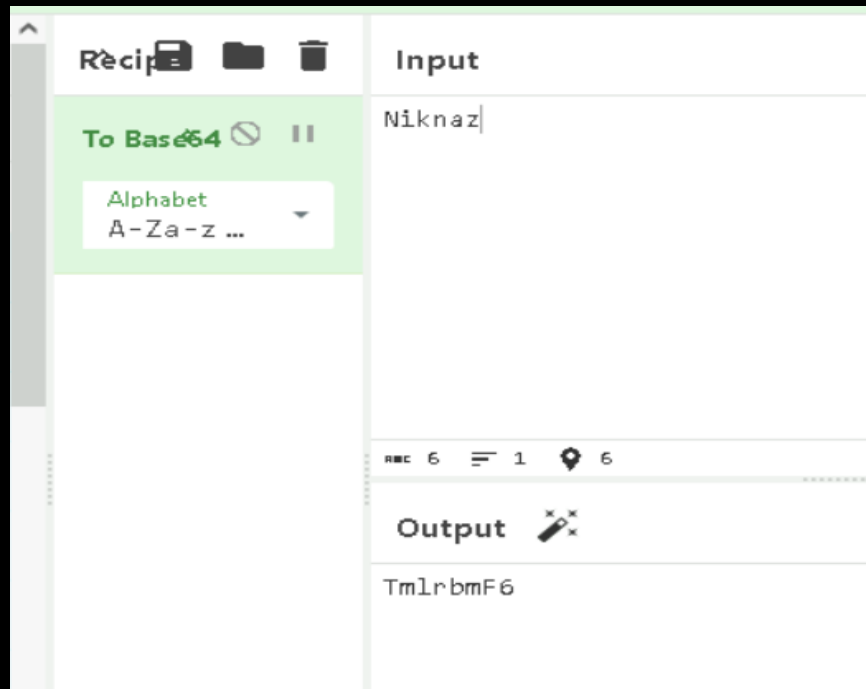


- I used net user to create a local test account named Niknazadmin in the authorized laboratory. Windows reported that the command completed successfully.
- I successfully added Niknazadmin to the local Administrators group using net localgroup. This privileged membership requires careful control; the lab action does not demonstrate unauthorized access or attacker privilege escalation.
- Entering the password in the command line exposed it in the screenshot and potentially in monitoring logs. An interactive password prompt is preferable in production.

Base64 Encoding with CyberChef

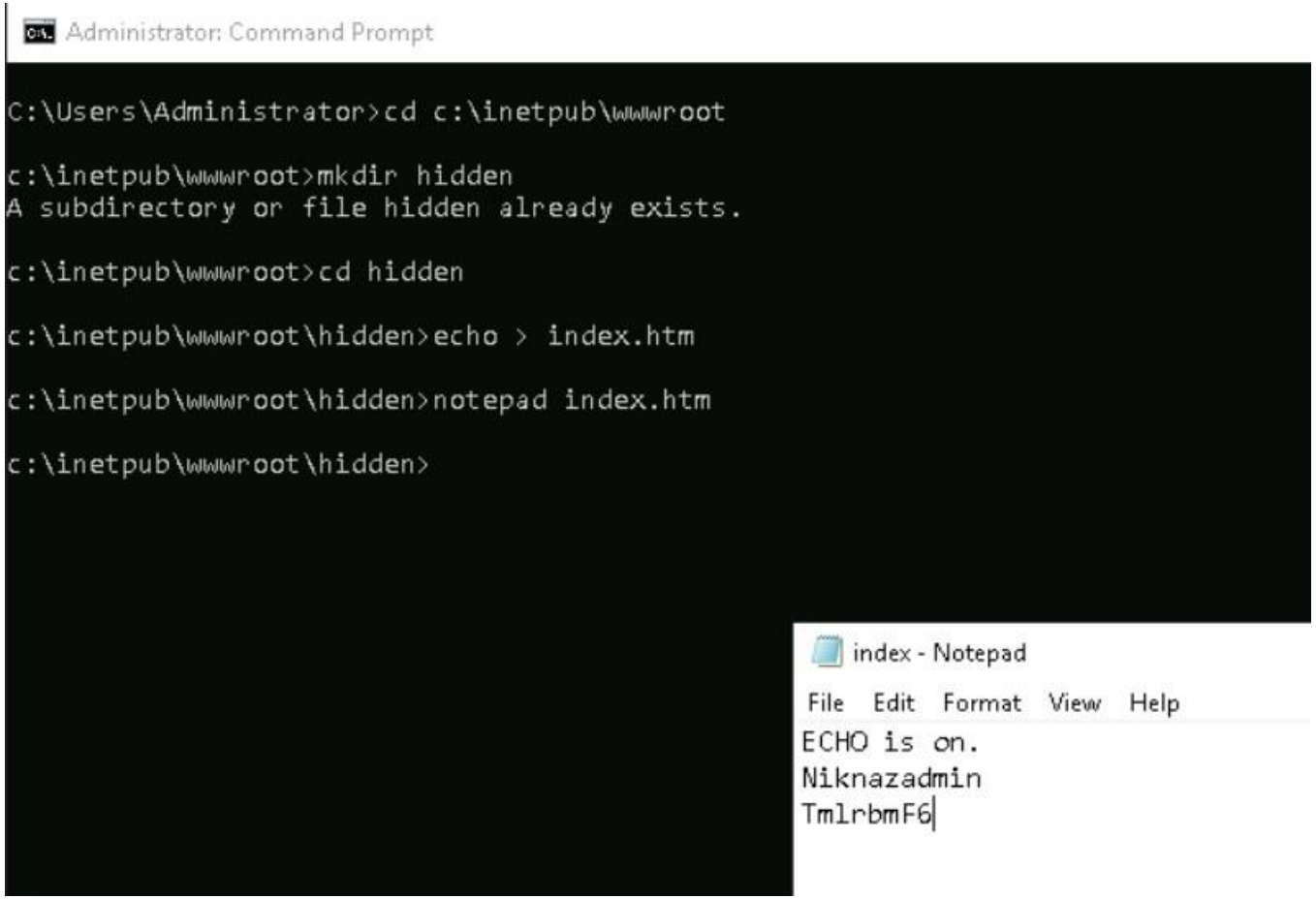
- I used CyberChef's **To Base64** operation to encode the ordinary text Niknaz in a controlled exercise.
- The output, TmlrbmF6, can be decoded back to Niknaz. Base64 is encoding, not encryption, and does not provide confidentiality.
- Analysts should recognize Base64 in logs, web content, and other artifacts. Encoded data may need further examination, but encoding alone is not evidence of malicious activity.



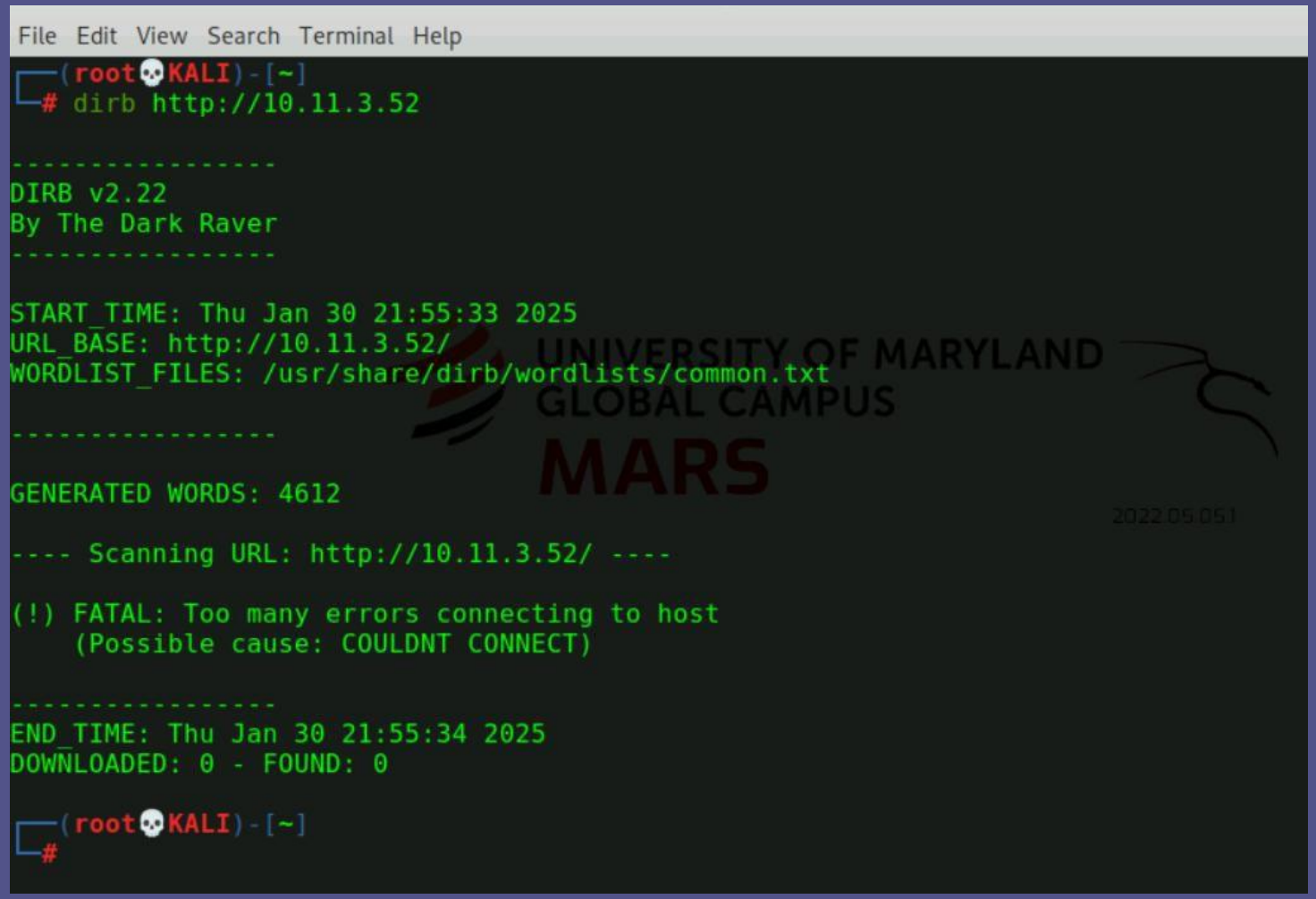


IIS Web Directory and Test File Setup

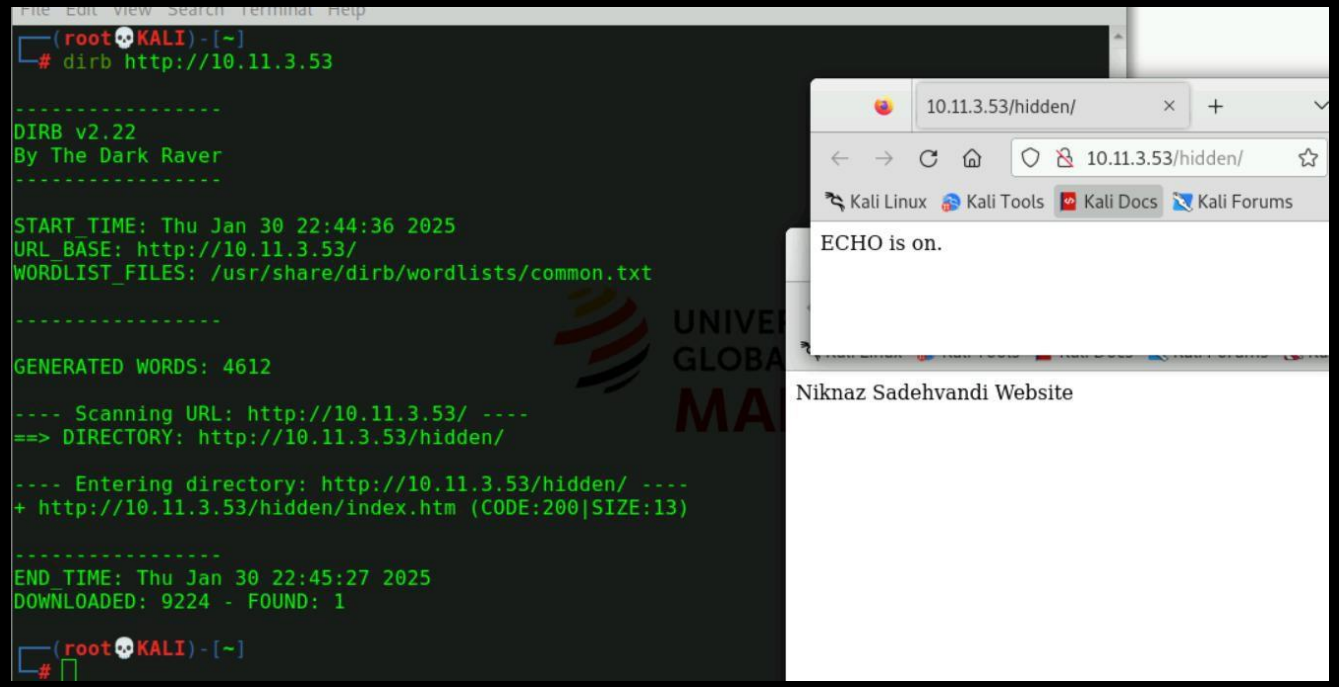
- **Directory:** I navigated to the IIS web root and accessed the existing hidden directory. Windows reported that it already existed; the captured mkdir command did not create it.
- **Test webpage:** I prepared index.htm in the test directory and examined its contents in Notepad.
- **Security relevance:** Web-directory access must be controlled to prevent exposure of sensitive content. These screenshots alone do not establish unauthorized access.



Dirb Directory Scan — Connection Failure



- **Scan attempt:** I ran Dirb against http://10.11.3.52 using its common wordlist.
- **Observed result:** Dirb reported connection errors and discovered no resources.
- **Interpretation:** The failed scan did not establish whether the host was secure or vulnerable. The screenshot did not identify the specific cause of the connection errors.



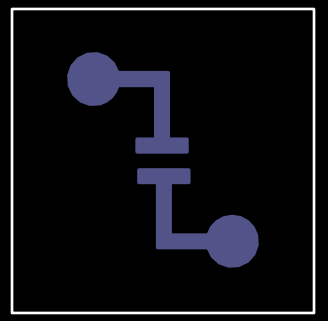
IIS Directory Discovery — Successful Scan

- **Scan performed:** I used Dirb against the Windows IIS laboratory server at 10.11.3.53 to identify accessible web directories and files.
- **Successful discovery:** Dirb found /hidden/ and reported HTTP 200 for /hidden/index.htm. The browser displayed “ECHO is on.”
- **Security interpretation:** Naming a directory hidden does not prevent discovery. Protection depends on access controls and server configuration, not the directory name.
- **Limitations and recommendations:** The result did not establish credential disclosure or unauthorized access. Directory permissions should be reviewed, and access to sensitive files restricted.

Summary



Investigation: I conducted an authorized security exercise in the UMGC MARS laboratory using Windows IIS and Dirb to examine web-directory discoverability. My initial scan of 10.11.3.52 failed with connection errors, while a later scan of 10.11.3.53 successfully identified accessible web resources.



Findings: Dirb discovered /hidden/ and received HTTP 200 for /hidden/index.htm, demonstrating that directory names alone do not restrict access. I also demonstrated Base64 encoding, but did not establish credential theft or exposure of real passwords. Resource discovery alone does not prove a vulnerability.



Conclusion: The exercise demonstrated how security testing can identify accessible web resources. I recommend reviewing directory permissions, restricting access to sensitive content, and monitoring unusual enumeration activity. These are security lessons—not evidence of a confirmed intrusion. The screenshots do not demonstrate malicious exploitation or unauthorized access.

References

Cybersecurity and Infrastructure Security Agency. (2024). *Top cybersecurity best practices*.

https://www.cisa.gov/sites/default/files/2024-12/Top-Cybersecurity-Best-Practices-Basic-Final-508.pdf

Government Communications Headquarters. (n.d.). *CyberChef*. GitHub.

https://github.com/gchq/CyberChef

Kali Linux. (n.d.). *Dirb — Web content scanner*.

https://www.kali.org/tools/dirb/

Microsoft. (n.d.). *Deploy and configure Internet Information Services*. Microsoft Learn.

https://learn.microsoft.com/en-us/training/modules/deploy-configure-internet-information-services/

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST CSWP 29).

https://doi.org/10.6028/NIST.CSWP.29

Stallings, W., & Brown, L. (2012). *Computer security: Principles and practice* (2nd ed.). Pearson.

https://books.google.com/books?vid=ISBN9780132775069